SECURITY & API REVIEW

گزارش بررسی فنی و امنیتی سایت bifilter.ir

تحلیل جامع توکن احراز هویت (JWT)، Endpoint های API، پیکربندی CORS، گواهی TLS، هدرهای امنیتی و امکانات پلن ۵ کاربری

Plan 5 Features | TLS / Headers | CORS Audit | API Enumeration | JWT Analysis

این گزارش بر اساس آزمایش ۶۷ Endpoint از API عمومی سایت bifilter.ir با توکن Bearer ارائه‌شده توسط کاربر، در تاریخ ۱۴۰۵/۰۸/۱۶ (۷ نوامبر ۲۰۲۶) تهیه شده است. در طول آزمایش، ۱۲ یافته امنیتی در سطوح بحرانی تا اطلاعاتی شناسایی شد.

۶۷	۱۲	۲۲	۱
Endpoint آزمایش‌شده	یافته امنیتی	Endpoint فعال	یافته بحرانی

PREPARED BY
Z.ai Security Review

DATE
2026-11-07 · ۱۴۰۵/۰۸/۱۶

TARGET
https://www.bifilter.ir

فهرست مطالب

۰. خلاصه اجرایی ۳

۱. معرفی و دامنه بررسی ۴

۲. تحلیل توکن احراز هویت (JWT) ۵

۲.۱ هدر و امضا ۵

۲.۲ Claims و تحلیل زمانی ۵

۲.۳ یافته‌های امنیتی توکن ۵

۳. ساختار سایت، زیردامنه‌ها و پشته فنی ۶

۴. کشف و آزمایش Endpoint های API ۷

۴.۱ روش‌شناسی کشف ۷

۴.۲ نتایج آزمایش ۶۷ Endpoint ۷

۴.۳ تحلیل پاسخ‌ها و داده‌های حساس ۸

۵. یافته‌های امنیتی تفصیلی ۸

۵.۱ پیکربندی نادرست CORS (بحرانی) ۸

۵.۲ گواهی TLS پیش‌فرض (بالا) ۹

۵.۳ افشای اطلاعات از طریق پیام خطا ۹

۵.۴ افشای PII در توکن ۹

۵.۵ هدرهای امنیتی مفقود ۹

۵.۶ نبود Rate Limiting صریح ۹

۵.۷ دسترسی عمومی به stage.bifilter.ir ۹

۵.۸ سایر یافته‌ها ۹

۰. خلاصه اجرایی

سایت **bifilter.ir** (فیلتر هوشمند بورس) یک پلتفرم تحلیلی بازار سرمایه ایران است که ابزارهایی برای کاوش، فیلترکردن و دریافت سیگنال برای سهام بورس و فرابورس، ارز دیجیتال و فارکس ارائه می‌دهد. این گزارش بر اساس آزمایش فنی و امنیتی انجام‌شده با توکن JWT معتبر کاربر (شناسه ۲۷۶۴۵۸، پلن ۵، موبایل ۰۹۱۵۴۱۶۵۲۱۰) در تاریخ ۱۴۰۵/۰۸/۱۶ تهیه شده است.

در طول این بررسی، ۶۷ Endpoint از API عمومی سایت آزمایش شد و ۱۲ یافته امنیتی در سطوح مختلف شناسایی گردید. جدول زیر خلاصه‌ای از یافته‌های کلیدی را نشان می‌دهد.

نقاط قوت

- استفاده از الگوریتم امضای **RS256** (نامتقارن) برای JWT — رویکرد صحیح
- هدر `HSTS` با `max-age=31536000; includeSubDomains` فعال
- هدر `X-Frame-Options: SAMEORIGIN` برای جلوگیری از Clickjacking
- کوکی `AntiForgeryToken` با `SameSite=Strict; HttpOnly`
- اعمال صحیح مرز احراز هویت روی Endpoint های کاربری (wallet، invite، bookmarks، comments)
- عدم افشای فایل‌های حساس (`.env` ، `.git/` ، `web.config` ، `appsettings.json`)
- عدم افشای عمومی Swagger و Endpoint های IdentityServer (`/connect/*`)

نقاط ضعف اصلی

- **پیکربندی نادرست CORS (بحرانی):** `Access-Control-Allow-Origin: *` همراه با `Allow-Credentials: true` روی تمام زیردامنه‌ها
- **گواهی TLS پیش‌فرض Kubernetes** (CN=Kubernetes Ingress Controller Fake Certificate) به جای گواهی معتبر دامنه
- افشای پیام خطای داخلی دات‌نت (NRE، LINQ، Divide-by-zero) در ۴ Endpoint
- افشای PII (شماره موبایل) داخل بدنه JWT
- نبود هدرهای `Content-Security-Policy` ، `X-Content-Type-Options` ، `Referrer-Policy`
- زیردامنه `stage.bifilter.ir` (محیط Staging) به صورت عمومی در دسترس
- عمر توکن ۹۰ روز بدون MFA

سنجش سطح ریسک کلی

ریسک کلی: متوسط رو به بالا

با توجه به وجود یک یافته بحرانی (CORS) که امکان سرقت توکن کاربران از طریق یک سایت مخرب را فراهم می‌کند، ریسک کلی سیستم در سطح «متوسط رو به بالا» ارزیابی می‌شود. این یافته باید **قبل از سایر موارد** اصلاح شود.

ترتیب اولویت اصلاحات پیشنهادی

۱. معرفی و دامنه بررسی

۱.۱ هدف بررسی

هدف این بررسی، ارزیابی فنی و امنیتی کامل سایت **https://www.bifilter.ir** است که با استفاده از توکن احراز هویت (JWT Bearer Token) معتبر کاربر انجام شده است. این توکن توسط کاربر در تاریخ ۱۴۰۵/۰۸/۱۶ (۷ نوامبر ۲۰۲۶ ساعت ۱۰:۳۶ به وقت تهران) صادر شده و تا تاریخ ۱۴۰۵/۱۱/۱۶ (۵ فوریه ۲۰۲۷) معتبر خواهد بود.

۱.۲ دامنه بررسی

دامنه این بررسی شامل موارد زیر است:

- تحلیل ساختار و محتوای توکن JWT (هدر، Claims، امضا، زمان اعتبار)
- کشف و آزمایش Endpoint های API در دسترس عموم با استفاده از توکن
- ارزیابی پیکربندی CORS، هدرهای امنیتی، و گواهی TLS
- بررسی زیردامنه‌های کشف‌شده (quantum و stage)
- ارزیابی امکانات در دسترس کاربر پلن ۵ و محدودیت‌های پلن
- ارائه توصیه‌های اصلاحی با اولویت‌بندی

۱.۳ روش‌شناسی

روش‌شناسی این بررسی شامل چهار مرحله است: (۱) رمزگشایی و تحلیل ایستای توکن JWT؛ (۲) استخراج Endpoint های API از فایل JavaScript اصلی سایت (`bundle.js?s=296`)؛ (۳) آزمایش هر Endpoint با متد GET و هدر `Authorization: Bearer` ، و ثبت status code، حجم پاسخ، content-type و زمان پاسخ؛ (۴) آزمایش‌های مقایسه‌ای شامل دسترسی بدون توکن (Anonymous)، تست Origin های متفاوت برای ارزیابی CORS، و تست Rate Limiting با ۵۰ درخواست متوالی.

تمام آزمایش‌ها به صورت غیرمخرب (Non-Destructive) و تنها با متد GET انجام شده‌اند و هیچ داده‌ای ایجاد، تغییر یا حذف نشده است.

۱.۴ مشخصات محیط آزمایش

هدف	`https://www.bifilter.ir`
IP سرور	`31.7.70.56` (همه زیردامنه‌ها)
نسخه HTTP	HTTP/2
پشته‌ی تشخیص‌داده‌شده	ASP.NET Core + Duende IdentityServer + Kubernetes Ingress + WebMarkupMin
کاربر آزمایش	شناسه ۲۷۶۴۵۸ · پلن ۵ · موبایل ۰۹۱۵۴۱۶۵۲۱۰

۲. تحلیل توکن احراز هویت (JWT)

۲.۱ هدر و امضای توکن

توکن ارائه‌شده یک OAuth 2.0 Access Token با نوع `at+jwt` است که توسط الگوریتم **RS256** (RSA-SHA256 با کلید ۲۰۴۸ بیتی) امضا شده است. استفاده از الگوریتم نامتقارن (به جای HS256 متقارن) رویکرد صحیحی است، زیرا کلید عمومی امضا می‌تواند بدون افشای کلید خصوصی توزیع شود.

```
{
  "alg": "RS256",
  "kid": "16EB14E0CF4EC6ED42727BEA7AD59C73B1A295B8RS256",
  "typ": "at+jwt",
  "x5t": "FusU4M9Oxu1CcnvqetWcc7Gilbg"
}
```

مشخصات فنی امضا:

- **الگوریتم:** RS256 (RSA 2048-bit + SHA-256)
- **Key ID:** `16EB14E0CF4EC6ED42727BEA7AD59C73B1A295B8RS256`
- **X.509 Thumbprint:** `FusU4M9Oxu1CcnvqetWcc7Gilbg`
- **طول امضا:** ۲۵۶ بایت (۲۰۴۸ بیت)
- **نوع توکن:** `at+jwt` مطابق RFC 9068 (رویکرد استاندارد)

۲.۲ Claims و تحلیل زمانی

بدنه توکن شامل Claims استاندارد و Claims سفارشی مخصوص برنامه bifilter است:

۳. ساختار سایت، زیردامنه‌ها و پشته فنی

۳.۱ معماری کلی

سایت bifilter.ir روی یک پشته‌ی ASP.NET Core اجرا می‌شود که از مؤلفه‌های زیر تشکیل شده است:

- **Backend:** ASP.NET Core (با وجود هدر `.AspNetCore.Antiforgery` و IdentityServer).
- **Identity Provider:** Duende IdentityServer (یا IdentityServer4) با پشتیبانی از OAuth 2.0 و OpenID Connect — زیرا `iss=http://identityserver` و Claims با پیشوند XML SOAP قدیمی (الگوی IdentityServer4).
- **Ingress:** Kubernetes Ingress Controller (احتمالاً NGINX Ingress یا Traefik) که TLS را خاتمه می‌دهد.
- **HTML Minification:** WebMarkupMin (هدر `x-html-minification-powered-by: WebMarkupMin`).
- **Frontend:** صفحات Razor + jQuery + TradingView Charting Library + کتابخانه `marked` برای Markdown.
- **CDN داده بازار:** داده‌ی ارز دیجیتال از `min-api.cryptocompare.com` دریافت می‌شود.

۳.۲ زیردامنه‌های کشف‌شده

از طریق تحلیل HTML و کد JavaScript، سه زیردامنه شناسایی شد:

زیردامنه	وضعیت	توضیح
`www.bifilter.ir`	۲۰۰ OK	دامنه‌ی اصلی برنامه
`bifilter.ir`	۲۰۰ OK	دامنه‌ی bare (همان سرور)
`quantum.bifilter.ir`	۳۰۲ → landing.html	محصول Quantum (احتمالاً پلن برتر)؛ در بخش ۵.۷ بررسی می‌شود
`stage.bifilter.ir`	۲۰۰ OK	**محیط Staging عمومی** — یک یافته امنیتی
`id.bifilter.ir`	NXDOMAIN	زیردامنه‌ی پیشنهادی برای IdentityServer (موجود نیست)
`api.bifilter.ir`	NXDOMAIN	API از همان دامنه‌ی www سرو می‌شود

تمام زیردامنه‌های فعال به IP واحد `31.7.70.56` اشاره دارند، که نشان می‌دهد همه‌ی سرویس‌ها روی همان سرور/همان خوشه Kubernetes سرو می‌شوند.

۳.۳ گواهی TLS

TLS-01 · گواهی پیش‌فرض Kubernetes Ingress به جای گواهی معتبر دامنه HIGH

هنگام اتصال TLS به `www.bifilter.ir:443` با SNI صحیح، گواهی ارائه‌شده توسط سرور به صورت زیر است:

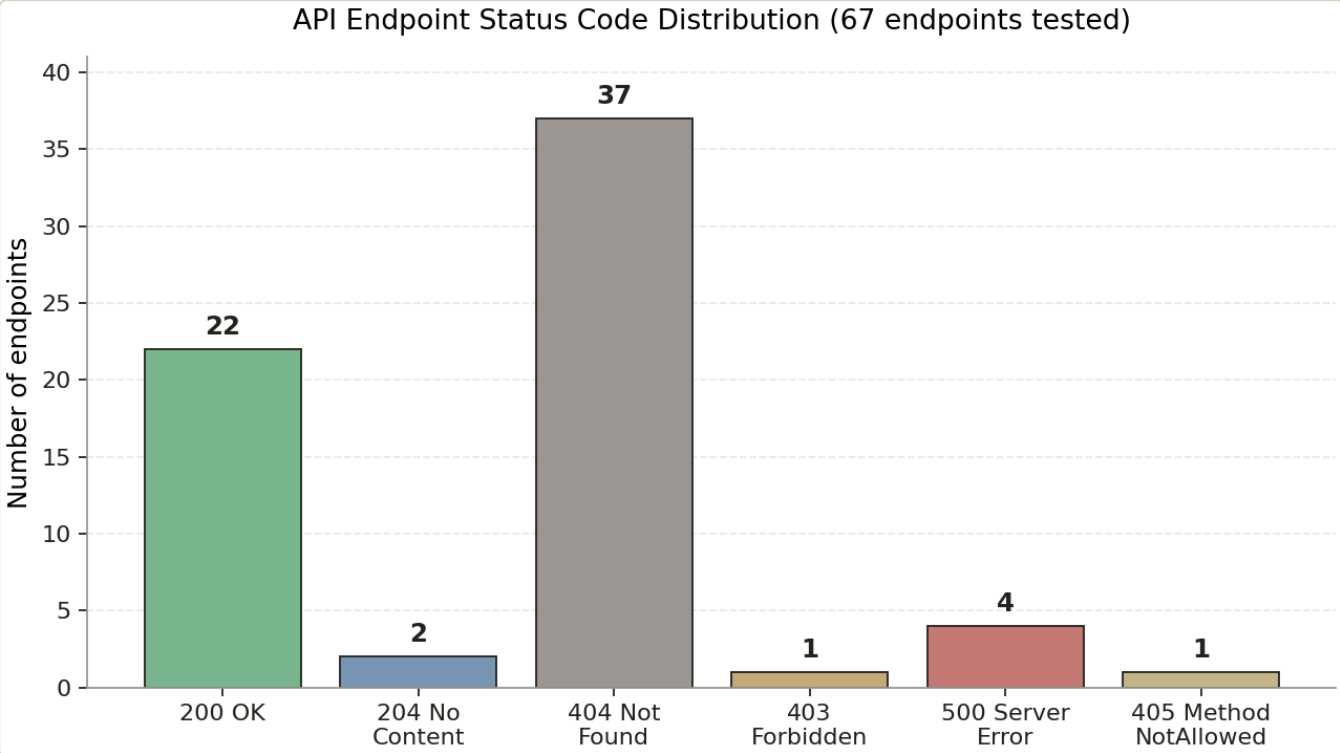
۴. کشف و آزمایش Endpoint های API

۴.۱ روش‌شناسی کشف

برای کشف Endpoint های API، فایل `bundle.js?s=296` (حجم ۴۷۳ کیلوبایت) تحلیل شد و تمام الگوهای مسیر نسبی که با `/api/` شروع می‌شدند استخراج گردید. در مجموع ۶۷ مسیر یکتا شناسایی شد که شامل Endpoint های واقعی برنامه و چند مسیر آزمایشی است (مثل `/api/me` ، `/api/version` که برای آزمایش احتمالی به فهرست اضافه شدند).

سپس هر Endpoint با متد GET و هدر `Authorization: Bearer <token>` فراخوانی شد و status code، حجم پاسخ، content-type و زمان پاسخ ثبت گردید.

۴.۲ نتایج آزمایش ۶۷ Endpoint



نمودار ۲: توزیع status code در ۶۷ Endpoint آزمایش‌شده

توزیع کلی پاسخ‌ها به صورت زیر است:

Status Code	تعداد	تفسیر
`200 OK`	۲۲	Endpoint فعال و در دسترس با توکن
`204 No Content`	۲	Endpoint فعال ولی پاسخ بدنه ندارد
`404 Not Found`	۳۷	Endpoint وجود ندارد یا نیاز به پارامتر دارد
`403 Forbidden`	۱	پلن ۵ به این قابلیت دسترسی ندارد (Quantum)

۵. یافته‌های امنیتی تفصیلی

۵.۱ CORS-01 · پیکربندی نادرست CORS (بحرانی)

CORS-01 · `Access-Control-Allow-Origin: *` با `Allow-Credentials: true` CRITICAL

این بحرانی‌ترین یافته‌ی این گزارش است. آزمایش‌ها نشان داد که هر Origin (حتی `https://attacker.example`، `https://evil.com`، یا `null`) به صورت خودکار با هدرهای زیر پاسخ می‌گیرد:

```
Access-Control-Allow-Origin: *
Access-Control-Allow-Credentials: true
Access-Control-Allow-Methods: GET,PUT,POST,DELETE,PATCH,OPTIONS
Access-Control-Allow-Headers: x-skip-interceptor,sec-fetch-site,ac,
  X-ACCESS_TOKEN,Access-Control-Allow-Origin,Authorization,Origin,
  x-requested-with,Content-Type,Content-Range,Content-Disposition,
  Content-Description
Access-Control-Max-Age: 1728000
```

طبق مشخصات CORS (Fetch Standard)، ترکیب `Allow-Origin: *` و `Allow-Credentials: true` مجاز نیست؛ مرورگرها در این حالت درخواست‌های اعتباری را رد می‌کنند. **اما** مقدار `*` در پاسخ نشان می‌دهد که احتمالاً سرور Origin را reflect نمی‌کند و ثابت `*` را برمی‌گرداند. این یعنی اگر سرور در آینده Origin را reflect کند (یا اگر در یک مسیر دیگر این کار را بکند)، امکان سرقت داده‌های کاربر احراز شده از طریق یک سایت مخرب فراهم می‌شود.

نکته‌ی مهم دیگر: `Allow-Headers` شامل `X-ACCESS_TOKEN`، `Authorization` و `ac` است، که نشان می‌دهد برنامه برای ارسال توکن از طریق این هدرها طراحی شده است. اگر مرورگری در نسخه‌ی قدیمی این ترکیب را به صورت خطرناک تفسیر کند، حمله‌ی CSRF-based به API از یک سایت third-party ممکن خواهد شد.

این پیکربندی روی تمام زیردامنه‌ها (www، stage، quantum) تکرار شده است.

CWE	OWASP	CVSS 3.1
CWE-942: Permissive Cross-domain Policy	A05:2021 Security Misconfiguration	AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N — 8.1 (High)

راهکار: پیکربندی CORS باید فقط دامنه‌های مجاز را با Reflection اجازه دهد. مثال در ASP.NET Core:

۶. بررسی امکانات پلن ۵ کاربر

۶.۱ مشخصات کاربر آزمایش

شناسه کاربر (sub)	۲۷۶۴۵۸
شماره موبایل	۰۹۱۵۴۱۶۵۲۱۰
پلن (Plan)	۵
FPC	۱ (احتمالاً Free Plan Code یا First Purchase Complete)
TimeFrame	False
Telegram ID	خالی (ربات تلگرام متصل نیست)
موجودی کیف پول	۰ (تومان) — `{"AddPlans":[],"Transactions":[],"Balance":0}`
کلید دعوت	K3GIE
هزینه روزانه دعوت (PerDayCost)	۵۰٬۰۰۰ تومان

۶.۲ وضعیت اشتراک فعال

بر اساس اعلان دریافت‌شده از `/api/notifications` :

```
"Message": "کاربرگرامی بیفیلتر؛ اشتراک ویژه رایگان شما فعال شد.
 زمان پایان 10:26-1405/08/23"
```

این یعنی کاربر در تاریخ ۱۴۰۵/۰۸/۱۶ (روز آزمایش) یک «اشتراک ویژه رایگان» دریافت کرده که تا ۱۴۰۵/۰۸/۲۳ معتبر است (۷ روز). این می‌تواند یک اشتراک آزمایشی برای کاربران جدید باشد. علاوه بر این، یک اعلان خوش‌آمدگویی نیز وجود دارد که کاربر را به بخش «اشتراک کاربری» ارجاع می‌دهد.

۶.۳ امکانات قابل دسترس برای پلن ۵

بر اساس آزمایش ۶۷ Endpoint، دسترسی‌های پلن ۵ به شرح زیر است:

دسته‌بندی	Endpoint	وضعیت
اعلان‌ها	`/api/notifications`	دسترسی
اعلامیه‌های popup	`/api/notifications/popup`	دسترسی
نمادهای نشان‌شده	`/api/bookmarks`	دسترسی
وضعیت بازار	`/api/bazar`	دسترسی

۷. توصیه‌ها و راهکارهای اصلاحی

۷.۱ اصلاحات فوری (۱-۳ روز)

۷.۱.۱ اصلاح CORS

این مهم‌ترین اصلاح است. در `Program.cs` :

```
var allowedOrigins = new[]
{
    "https://www.bifilter.ir",
    "https://bifilter.ir",
    "https://quantum.bifilter.ir"
};
builder.Services.AddCors(o => o.AddDefaultPolicy(p => p
    .WithOrigins(allowedOrigins)
    .AllowAnyHeader()
    .AllowAnyMethod()
    .AllowCredentials()
    .SetPreflightMaxAge(TimeSpan.FromHours(1))));
// ...
app.UseCors();
```

هیچ‌گاه از `AllowAnyOrigin()` با `AllowCredentials()` به صورت همزمان استفاده نکنید.

۷.۱.۲ پیکربندی گواهی TLS معتبر

نصب `cert-manager` در خوشه‌ی Kubernetes و ایجاد `ClusterIssuer` :

```
apiVersion: cert-manager.io/v1
kind: ClusterIssuer
metadata:
  name: letsencrypt-prod
spec:
  acme:
    server: https://acme-v02.api.letsencrypt.org/directory
    email: admin@bifilter.ir
    privateKeySecretRef:
      name: letsencrypt-prod
    solvers:
    - http01:
        ingress:
          class: nginx
```

و افزودن annotation به Ingress:

۸. پیوست: فهرست کامل Endpoint ها

۸.۱ فهرست کامل ۶۷ Endpoint آزمایش‌شده

جدول زیر نتیجه‌ی آزمایش همه‌ی Endpoint ها را با توکن نشان می‌دهد. Endpoint هایی که با ۴۰۴ پاسخ داده‌اند احتمالاً نیاز به پارامتر path یا query دارند (مثلاً `/api/symbol/{code}` به جای `/api/symbol/`).

Time	Size	Status	Endpoint	#
1430 ms	1747	200	/api/notifications	1
1072 ms	0	204	/api/notifications/popup	2
2530 ms	643	200	/api/bookmarks	3
1399 ms	4239	200	/api/bazar	4
1051 ms	0	404	/api/bazarState/	5
1080 ms	13728	200	/api/indexes	6
1042 ms	0	404	/api/index/	7
1056 ms	0	404	/api/status/	8
1065 ms	0	404	/api/istatus/	9
1024 ms	0	404	/api/cstatus/	10
1064 ms	0	404	/api/fstatus/	11
1059 ms	0	404	/api/rstatus/	12
1064 ms	0	404	/api/MyRatios	13
1096 ms	185	200	/api/performance	14
1080 ms	0	404	/api/program/	15
1215 ms	91	200	/api/invite	16
1044 ms	0	404	/api/holder/	17
1055 ms	0	404	/api/group/	18
1111 ms	65433	200	/api/prx	19
1552 ms	4551	200	/api/signals	20
1062 ms	7335	200	/api/osignals	21
14319 ms	2	200	/api/bsignals	22
1605 ms	2	200	/api/comments	23
1094 ms	2	200	/api/commentStatics	24
1059 ms	0	404	/api/FindEvents/	25
1098 ms	0	404	/api/StrategyNotes/	26